

IMPORTANT NOTICE



PROTECTING HEALTH. POWERING CARE.

This document was created as part of a fictional cybersecurity capstone scenario. HealthSecure Systems (HSS), all users, systems, IP addresses, incident data, and business information shown are simulated and intended solely for educational portfolio use.



CONFIDENTIAL | FOR EXECUTIVE LEADERSHIP ONLY





CONFIDENTIAL — EXECUTIVE BRIEFING

Security Breach

Incident Response Executive Briefing

HealthSecure Systems (HSS)

Incident Response Team | July 4th 2026 | Ryan Coyle

RESTRICTED
Internal Use Only





BREACH SUMMARY



PROTECTING HEALTH. POWERING CARE.



DETECTION

Snort IDS alerted on suspicious activity from Workstation-23

Windows logs showed PowerShell payload activity

Zeek logs confirmed HR server access and Dev server targeting

Honeypot detected failed DMZ access using former employee credentials



IMPACT

Payroll & PII exposure risk

Regulatory / compliance exposure

Operational disruption across Finance, HR and Development

Loss of client and partner trust



RESPONSE

System logs, Snort alerts, and network traffic reviewed

Workstation-23 isolated to stop further spread

Outbound connections to the malicious domain blocked

Recovery completed; 30-day monitoring started





POTENTIAL BUSINESS IMPACTS



PROTECTING HEALTH. POWERING CARE.

01

Data Integrity & Confidentiality



- If an attacker accessed/changed any sensitive information exclusive to HSS, it could affect data accuracy, confidentiality, and business decision-making.

02

HIPAA / Compliance Failure



- Exposure of patient-related or employee data could create regulatory concerns, reporting obligations, and possible financial penalties.

03

Operational Continuity



- Poor off-boarding controls could continue to put HSS at risk
- Further spread of the attack could disrupt payroll, internal operations, software development or client support

04

Patient & Partner Trust



- Our clients rely on us to protect sensitive healthcare and business information
- A breach can damage confidence, harm reputation, create doubts of our security strength





Evidence Item	Status	Source
Payroll-themed email sent to Finance user with suspicious file link	Confirmed	Phishing email extract
Successful logon activity involving former user jcampbell credentials	Confirmed	Windows Event Log
Psexec service installed during the incident window (Potential System Compromise)	Confirmed	Windows Event Log / Snort Alert Log
PowerShell command used to download a suspicious payload	Confirmed	Windows Event Log
RDP session established to HR SQL database	Confirmed	Zeek Log
Outbound connection to suspicious external destination	Confirmed	Zeek Log
2 Attempts: SSH login to Development DMZ server by jcampbell	Confirmed	Zeek / Snort / Honeypot





KNOWN EVIDENCE CONT.



PROTECTING HEALTH. POWERING CARE.

Evidence Item	Status	Source
PowerShell logging disabled on about 30% of Windows machines	Confirmed Gap	Internal Memo
Manual user de-provisioning and active former employee accounts	Confirmed Gap	Internal Memo
No phishing simulation or tabletop exercise in last 18 months	Confirmed Gap	Internal Memo
Downloaded PowerShell payload is obfuscated and may include credential harvesting	Under Review	IT Forensics Update
jcampbell credentials found in cached credential store on Workstation-23	Confirmed	IT Forensics Update
DevAppServer AV status "Unknown" and no EDR alert triggered	Confirmed Gap	IT Forensics Update / Asset Inventory

Key Metrics

**1 Workstation, 1 Server /
1 Server**

Compromised / Targeted

Payroll/Finance, PII

Data records at risk

1:24 AM - 2:11 AM

Duration of Attack Activity

3:01 AM

Containment Started

Phishing email

Attack Vector



INITIAL INDICATORS OF COMPROMISE (IoCs) PROTECTING HEALTH. POWERING CARE.



Network IoCs

192.168.1.45 → 45.77.33.88

Finance workstation connected to suspicious external destination

maliciousdomain.xyz

Domain used to download suspicious PowerShell payload

secure-download.com

Domain tied to suspicious payroll-themed email link

192.168.1.45 → 192.168.1.88

SMB/RDP connection to compromised HR server

192.168.1.45 → 192.168.1.200

Attempted connection toward Development DMZ server



Host-Based IoCs

Workstation-23 / 192.168.1.45

Confirmed compromised Finance workstation

PowerShell payload download

Indicates suspicious script execution on the workstation

Obfuscated payload

May hide malicious activity such as credential collection

PsExecsvc installed

Remote execution activity tied to lateral movement

cmd.exe /c whoami

Common command to enumerate current user privileges



Account IoCs

jcampbell

Former employee account involved in suspicious activity

Cached jcampbell credentials on Workstation-23

Indicates possible credential exposure or reuse risk

Failed SSH login using jcampbell

Attempted access to Development DMZ server

finance_user

Account used during suspicious PowerShell activity

accountant_jane

Recipient of phishing email and likely initial target





PROJECT GOALS



PROTECTING HEALTH. POWERING CARE.

01

Halt Attack and Minimize Business Disruption

Isolated the threat quickly while keeping critical operations running.

02

Assess Business Impact and Scope of the Breach

Identified compromised systems, targeted systems, and business risk.

03

Restore Secure Operations

Restored affected systems only after validation and security testing.

04

Identify Defensive Blind Spots

Evaluated current security tools to validate what worked and pinpoint where visibility failed.

05

Strengthen Organizational Resilience

Implement strategic upgrades to eliminate systemic vulnerabilities.





INCIDENT RESPONSE PLAN



PROTECTING HEALTH. POWERING CARE.

1

Preparation

Review IR Playbook

Assign response
roles

Preserve evidence

Coordinate
leadership updates

2

Identification

Confirm affected
systems

Review logs and
alerts

Identify impacted
accounts

Assess business
impact

3

Containment

Isolate
compromised
Workstations

Block malicious
domains/IPs

Disable risky
accounts

Limit access to
sensitive systems

4

Eradication

Remove suspicious
payload

Reset exposed
credentials

Remove stale user
accounts

Fix logging/EDR
gaps

5

Recovery

Rebuild affected
workstations

Validate servers

Restore normal
access safely

Monitor for repeat
activity

6

Lessons

Build final incident
timeline

Review response
gaps

Update IR
procedures

Improve training
and readiness





IMMEDIATE RESPONSE STRATEGY



PROTECTING HEALTH. POWERING CARE.



Short-term (0-6 hrs)

CONTAINMENT

Isolate Workstation-23

Disable jcampbell and other risky accounts

Block malicious IPs and domains

Preserve forensic evidence

Coordinate with Legal/Compliance

ERADICATION

Terminate malicious PowerShell on WS-23

Delete rogue PsExecsvc from HR SQL server

ID + extract malicious payload

Audit systems for backdoors

Reset systems to secure settings

RECOVERY

Verify data integrity of affected servers

Rebuild/clean Workstation-23 before reuse

Apply critical system patches

Test restored systems for function & security

Restore only validated systems

Mid-term (6-24 hrs)

Temporary strict firewall rules for HR/DMZ

Isolate high-risk assets

Strict access control for SMB/RDP/SSH traffic

Monitor Zeek/Snort to verify containment

Ensure critical operations safely continue

Thorough EDR scans to validate cleanliness

Review event logs to confirm threat absence

Fix weak internal access controls

Scan/disable all inactive accounts

Update Bitdefender EDR policies

Resume all services in deliberate phases

Expand monitoring for repeat activity

Enforce Multi-Factor Authentication

30-day strict monitoring of affected IPs

Update IR runbooks based on findings





LESSONS AND LONG-TERM IMPROVEMENTS



PROTECTING HEALTH. POWERING CARE.

LESSONS LEARNED



Offboarding Vulnerabilities

- Manual offboarding left former accounts active
- Stale accounts increase risk
- Unsustainable for future resilience



Visibility/Investigation Friction

- IR process managed by a 3 person team
- Lack of SIEM + small team = delayed response
- DevAppServer: no EDR alert + AV unknown



Human + Network Gaps

- Phishing email reached Finance user
- Finance workstation compromised
- Poor segmentation/ACLs
- Basic IR playbook and no recent tabletop exercises

IMPROVEMENTS



Account Offboarding

- Automate account deactivation
- Instant and Reliable
- Reduces risk from former employee credentials



Deploy SIEM + Unify EDR

- SIEM for enhanced security and analysis
- Standardize + audit EDR policies
- Improved visibility and reduced detection time with same headcount



IR Preparedness + Training

- Update IR playbook for attack chains
- Quarterly tabletop exercises
- Role-based training
- Enhance network segmentation
- Deploy advanced email security gateways





PROJECT TIMELINE & SCOPING PLAN



PROTECTING HEALTH. POWERING CARE.

